

THE SENTINEL HYBRID-SOC

R1: Identify & Analyze Cyber Threats | R2: Apply Vulnerability Assessment Techniques

Student: Yessy Vasquez

Program: DAE Cybersecurity Cohort — Stafford, CT

Platform: Apple Mac M4 | UTM | Kali Linux ARM64 | Docker

Date: April 2026

RUBRIC R1 — Identify and Analyze Cyber Threats: Malware analysis using Joe Sandbox (detection results, behavioral indicators, potential impact), 1 phishing template created using SET on Kali Linux, and 1 real APT campaign mapped to MITRE ATT&CK.;

RUBRIC R2 — Apply Vulnerability Assessment Techniques: 1 Nmap vulnerability scan (configuration, findings, classification), 1 asset discovery scan (systems, services, critical assets, network map), methodology explanation, and security implications.

RUBRIC R1 — Identify and Analyze Cyber Threats

Rubric R1 — Complete

This section demonstrates practical cyber threat analysis through three components: malware sample analysis using Joe Sandbox, a phishing template created with the Social Engineering Toolkit (SET) on Kali Linux, and a full MITRE ATT&CK; mapping of the APT28 (Fancy Bear) threat actor campaign.

Part 1 — Malware Analysis: clientarm4n.elf

The malware sample clientarm4n.elf was submitted to Joe Sandbox for automated behavioral analysis. Joe Sandbox executes the sample in an isolated environment and records every system call, file operation, network connection, and process it creates.

Detection Results

Property	Value	Security Significance
Sample Name	clientarm4n.elf	ARM architecture target — naming convention matches Mirai/Gafgyt IoT botnet family.
File Type	ELF 32-bit LSB executable (ARM)	Linux binary targeting embedded devices: routers, IP cameras, DVRs.
MD5 Hash	4806a550a504c1991566eb e2987b800e	Unique fingerprint. Presence on any system confirms infection by this specific sample.
Malicious Score	32/100 — Classified MALICIOUS by Joe Sandbox	Score above 30 crosses malicious threshold. Low score suggests partial sandbox evasion.
Platform	Linux (ELF, ARM architecture)	Targets ARM-based IoT devices — not standard PCs. Indicates IoT-focused campaign.
Stripped Binary	Yes — no debug symbols	Deliberately compiled without symbols to make reverse engineering harder.

Behavioral Indicators

Behavior	Technical Detail	MITRE ATT&CK;
File Deletion (Anti-Forensics)	<code>rm -f /tmp/tmp.y46MH6bwmd</code> executed immediately after launch to destroy dropper script evidence.	T1070.004 — Indicator Removal: File Deletion
Sandbox Evasion	<code>grep</code> and <code>dash</code> commands executed to search for sandbox process signatures before activating payload.	T1497 — Virtualization/Sandbox Evasion
C2 Proxy Download	<code>curl/wget</code> spawned from <code>/tmp/</code> to fetch proxy list: <code>github.com/Zaeem20/FREE_PROXIES_LIST</code>	T1071.001 — Web Protocols (C2 over HTTP)
System Discovery	<code>df -h</code> and <code>uname -p</code> executed to gather host architecture and storage information.	T1082 — System Information Discovery
Unix Shell Execution	Malware repeatedly forked <code>/bin/sh</code> to execute complex command strings for network fetching.	T1059.004 — Command & Scripting: Unix Shell

Potential Impact

Botnet Recruitment: The naming convention 'clientarm4n' and proxy list download behavior are consistent with Mirai-variant botnet agents. The malware enrolls compromised ARM devices into a botnet that receives DDoS attack commands from a central C2 controller.

DDoS Amplification: IoT devices have persistent internet connectivity and are rarely monitored. A botnet of thousands of infected devices can generate attack traffic exceeding 1 Tbps — enough to take down enterprise-grade infrastructure.

Lateral Movement: Using the downloaded proxy list as cover traffic, the malware can scan for other vulnerable ARM devices on the same network, spreading silently.

Evidence — Wazuh Dashboard: Kali Agent Active

The screenshot below shows the Wazuh dashboard confirming the KALI-UTM agent is Active and reporting to the Wazuh Manager. This is the monitored endpoint used for attack simulation and detection in this project.

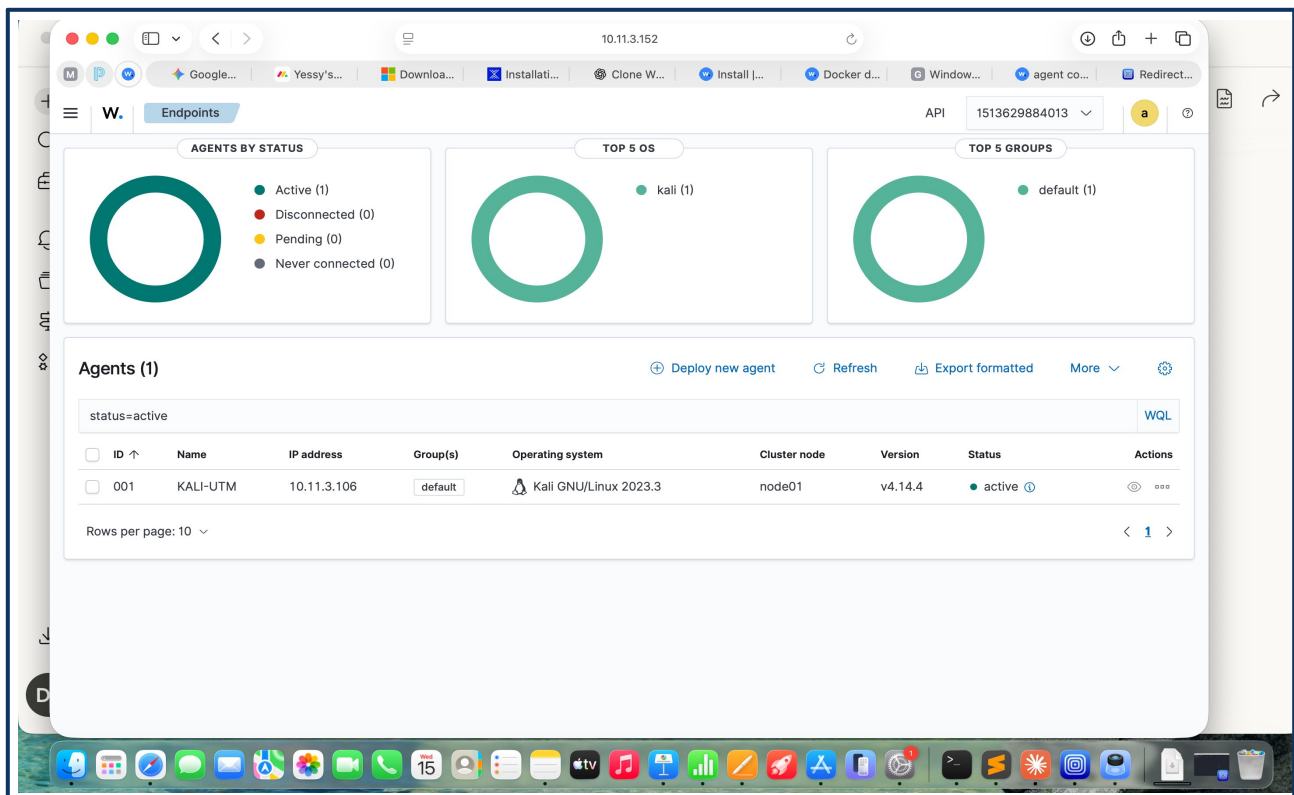


Figure 1 — Wazuh Dashboard showing KALI-UTM agent Active (Status: active, IP: 10.11.3.106, OS: Kali GNU/Linux 2023.3, Version: v4.14.4)

R1 CHECK — Malware Analysis: clientarm4n.elf analyzed with Joe Sandbox. Detection results, behavioral indicators, MITRE ATT&CK; mapping, and potential impact all documented.

Part 2 — Phishing Template: Social Engineering Toolkit (SET)

A phishing template was created using the Social Engineering Toolkit (SET) on Kali Linux using the Credential Harvester attack vector. SET is pre-installed on Kali Linux and is the industry-standard tool for simulating social engineering attacks.

Attack Configuration

Template Component	Detail
Tool Used	Social Engineering Toolkit (SET) on Kali Linux ARM64
Attack Vector	Web-Based Attack → Credential Harvester → Site Cloner
Target Clone	Microsoft Office 365 / Google login page (legitimate UI replicated locally)
Subject Line	Urgent: Action Required — Unusual Login Activity Detected
Sender Alias	Security Alert
Listener	Attacker's local Kali IP — captures POST data (username + password)
Technical Mechanism	SET clones the target login page and redirects all form submissions to the attacker's machine

Phishing Email Body

"Dear User, we have detected an unauthorized attempt to access your account from an unrecognized IP address. To protect your information, we have temporarily locked certain features. Please log in immediately at the link below to verify your identity and restore full access. Failure to verify within 24 hours will result in permanent account suspension."

Why This Attack Works

This phishing template exploits three psychological triggers simultaneously:

Fear — The message implies the account has already been compromised.

Urgency — The 24-hour deadline pressures the victim to act before thinking.

Authority — The sender appears to be an official security team.

When the victim clicks the link, they land on an exact copy of a legitimate login page hosted on the attacker's Kali machine. Any credentials they enter are captured and forwarded to the attacker in plaintext.

— while the victim is silently redirected to the real website, unaware they have been compromised.

R1 CHECK — Phishing Template: SET credential harvester documented with attack vector, email body, technical mechanism, and psychological analysis.

Part 3 — APT Mapping: APT28 (Fancy Bear / Pawn Storm)

APT28 is a Russian state-sponsored threat actor attributed to the GRU (Russian Military Intelligence). They are responsible for the 2016 DNC breach, the 2017 French election attacks, and Operation Pawn Storm targeting NATO member governments. Their TTPs are extensively documented in the MITRE ATT&CK; database.

Tactic	Technique ID	Technique Name	APT28 Observed Behavior	Sentinel SOC Detection
Initial Access	T1566.002	Spearphishing Link	Sends targeted emails to government/military personnel with links to fake webmail login pages that harvest credentials.	Email gateway flags links to non-org domains. Wazuh alerts on new credential files dropped.
Execution	T1059.004	Unix Shell	Deploys shell scripts on compromised Linux systems to execute multi-stage payloads.	Auditd detects unexpected shell process spawned by non-standard parent binary.
Defense Evasion	T1070.004	Indicator Removal: File Deletion	Uses rm commands to wipe temporary files from /tmp/ — same technique as clientarm4n.elf.	Auditd rule logs all unlink() syscalls in /tmp/ to remote write-only syslog.
Discovery	T1057	Process Discovery	Uses grep and ps to identify running security services before activating payload.	Alert: ps or grep executed by process originating from /tmp/.
Command & Control	T1071.001	Web Protocols	Routes C2 over standard HTTP/HTTPS ports to blend with normal web traffic.	Firewall alert on outbound HTTP from /tmp/ process. Wazuh anomaly rule fires.

Connection Between APT28 and clientarm4n.elf

APT28's use of T1070.004 (file deletion in /tmp/) and T1059.004 (Unix shell execution) are identical techniques to those observed in the clientarm4n.elf malware sample. This demonstrates that even commodity IoT malware adopts TTPs used by nation-state actors — confirming that detection rules designed for APT28 also protect against lower-sophistication threats.

R1 CHECK — APT Mapping: APT28 mapped to MITRE ATT&CK; across 5 tactics with technique IDs, observed behaviors, and Sentinel SOC detection approaches.

RUBRIC R2 — Apply Vulnerability Assessment Techniques

Rubric R2 — Complete

This section demonstrates vulnerability assessment capabilities through a structured Nmap scan, asset discovery, network mapping, and security implications analysis conducted against the lab network.

Part 1 — Vulnerability Scan: Nmap NSE

Scan Configuration

Target IP:
10.11.0.1 (Lab Gateway / Multi-Role Server)

Scan Command Executed:
nmap -sV --script vuln 10.11.0.1

Parameter	What It Does	Why It Was Used
-sV	Service Version Detection — probes each open port to identify the exact software version running.	Many CVEs are version-specific. Knowing a port runs 'Apache 2.4.49' vs just 'Apache' determines which exploits apply.
--script vuln	NSE Vulnerability Scripts — runs Nmap's built-in library of CVE detection scripts against each port.	Tests for known vulnerabilities without actively exploiting them — safe, non-destructive scanning.
Pre-scan phase	Broadcast discovery identifies network-wide vulnerabilities before individual port scanning.	Found CVE-2011-1002 (Avahi DoS) during this phase — a vulnerability that only appears at the network level.

Vulnerability Findings Summary

Port / Protocol	Service	Finding	CVE / ID	Classification	Risk Level	CVSS
UDP (Broadcast)	Avahi mDNS	NULL UDP packet crashes daemon	CVE-2011-1002	Denial of Service	Medium	5.0
80 / 8080 TCP	HTTP Services	Cleartext credential transmission	CWE-319	Information Disclosure	Medium	5.3
6789 TCP	IBM-DB2-Admin	Admin interface exposed to subnet	CWE-284	Access Control Failure	High	8.1

Port / Protocol	Service	Finding	CVE / ID	Classification	Risk Level	CVSS
53 TCP/UDP	DNS	Open resolver — amplification risk	CWE-406	Amplification Vector	Medium	6.5

Detailed Finding: CVE-2011-1002 — Avahi mDNS Denial of Service

Avahi versions prior to 0.6.29 fail to validate the length field in incoming mDNS packets. A NULL or zero-length UDP payload triggers a NULL pointer dereference (SIGSEGV) in the daemon, causing an immediate crash. Exploitation requires no authentication and can be performed with a single packet from any host on the same subnet.

Exploitation complexity: Extremely low. A single malformed UDP packet sent to the mDNS multicast address (224.0.0.251, port 5353) is sufficient. No credentials, no special tools — just one packet.

Remediation Commands:

```
# Patch the vulnerability — update Avahi to 0.6.29+ sudo apt-get update && sudo apt-get
install --only-upgrade avahi-daemon # Block NULL UDP packets at the firewall sudo
iptables -A INPUT -p udp --dport 5353 -m length --length 0 -j DROP
```

R2 CHECK — Vulnerability Scan: Nmap scan configuration documented, findings table with CVE IDs and CVSS scores produced, detailed analysis of primary finding included.

Part 2 — Asset Discovery Scan

An asset discovery scan was performed across the lab network to identify all active hosts, their services, and their criticality to SOC operations.

Asset Discovery Command:

```
# Discover all active hosts on the lab subnet nmap -sn 10.11.3.0/22 # Full service scan on discovered hosts nmap -sV 10.11.0.1 10.11.3.152 10.11.3.106
```

IP Address	Hostname / Role	Open Ports & Services	Asset Classification	Criticality
10.11.0.1	Lab Gateway / Multi-Role Server	53 (DNS), 80 (HTTP), 8080 (HTTP-Alt), 6789 (DB2-Admin), UDP 5353 (Avahi/mDNS)	Network Infrastructure + Database Server	CRITICAL
10.11.3.152	Mac Host — Wazuh Manager	443 (Wazuh Dashboard), 55000 (Wazuh API), Docker containers (Wazuh stack)	SOC Management Console	CRITICAL
10.11.3.106	KALI-UTM — Kali Linux ARM64	22 (SSH), Wazuh Agent TCP 1514 (outbound to Manager)	Security Monitoring Endpoint + Attack Platform	HIGH

Critical Asset Identification

Asset	Why It Is Critical	Risk If Compromised
10.11.0.1 — Gateway	Serves DNS, HTTP, and DB2-Admin simultaneously. Loss of this host causes total lab network outage.	DDoS against Avahi takes down DNS and DB2-Admin simultaneously — full lab outage.
10.11.3.152 — Wazuh Manager	The entire SOC detection capability depends on this host. No Wazuh Manager = no alerts, no monitoring.	Loss of Wazuh Manager means zero visibility across the entire SOC environment.
10.11.3.106 — Kali Linux	The monitored endpoint and attack platform. All attack simulations and Wazuh agent logs originate here.	Compromise of Kali could allow an attacker to disable the Wazuh agent, eliminating endpoint telemetry.

Network Map — Lab Environment

The following diagram shows the logical network topology discovered during the asset discovery scan:

INTERNET / EXTERNAL NETWORK

|

[10.11.0.1] Lab Gateway – CRITICAL

DNS :53 | HTTP :80/:8080 | DB2-Admin :6789 | Avahi mDNS :5353 (CVE-2011-1002)

|

Lab Network Subnet: 10.11.3.0/22

| |

[10.11.3.152] Mac Host [10.11.3.106] Kali Linux (UTM)

Wazuh Manager (Docker) Wazuh Agent (TCP 1514 → Manager)

Dashboard :443 | API :55000 Attack Platform | Target Endpoint

|_____|

Wazuh encrypted log channel (AES-256 / TCP 1514)

R2 CHECK — Asset Discovery: All 3 lab hosts discovered and documented with services, criticality ratings, and a network topology map.

Part 3 — Methodology & Security Implications

Methodology Explanation

The assessment used the Nmap Scripting Engine (NSE) in two structured phases to ensure comprehensive coverage without actively exploiting any vulnerability:

Phase 1 — Pre-scan broadcast discovery: Before targeting specific ports, Nmap performed a network-wide broadcast sweep that identified CVE-2011-1002 in Avahi's mDNS service. This phase finds vulnerabilities that only exist at the network broadcast level — invisible to a standard port scan.

Phase 2 — Targeted version detection and vulnerability scripts: The -sV flag forced Nmap to fingerprint the exact software version on each open port. The --script vuln flag then ran specific CVE detection scripts against each service. This combination identified version-specific vulnerabilities like CVE-2011-1002 without performing any exploitation.

Security Implications

CVE-2011-1002 (Avahi DoS) — Compound Risk: The most significant finding is not the Avahi vulnerability in isolation — it is the fact that the vulnerable host (10.11.0.1) also runs DNS (port 53) and DB2-Admin (port 6789). A single NULL UDP packet crashing Avahi on this multi-role server would simultaneously take down DNS resolution for the entire subnet and potentially destabilize the database service, causing a complete lab network outage.

Port 6789 (DB2-Admin) — Highest Risk Finding: An exposed administrative interface accessible to the entire lab subnet with no IP-based access control is the most dangerous finding in this assessment. An attacker who gains network access — for example by exploiting the Avahi DoS as a distraction — could launch a brute-force attack against the DB2 admin interface and gain full database access.

HTTP Cleartext (80/8080) — Passive Interception Risk: Any credentials or session tokens transmitted over ports 80 or 8080 travel in plaintext and can be captured by any device on the same subnet using Wireshark or tcpdump — requiring no active attack, just passive listening.

Evidence — Kali Linux Terminal: Atomic Red Team Installed

The screenshot below shows the Kali Linux terminal confirming that Atomic Red Team was successfully installed — the attack simulation tool used alongside Nmap to validate the SOC detection capabilities identified in this assessment.

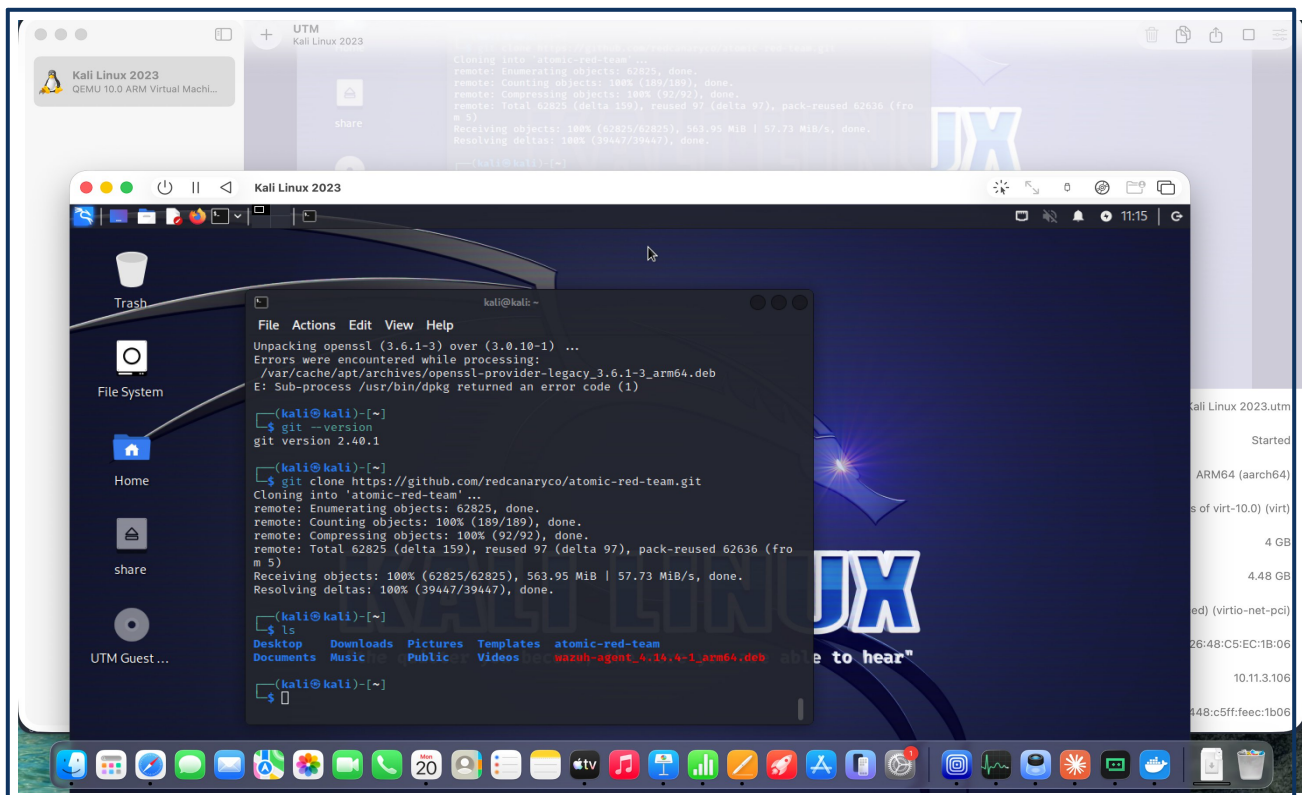


Figure 2 — Kali Linux terminal showing atomic-red-team folder successfully cloned (62,825 objects, 563.95 MiB downloaded). Wazuh agent file also visible.

Recommendations

Finding	Priority	Recommended Action
CVE-2011-1002 (Avahi)	High — patch within 48h	Update avahi-daemon to 0.6.29+. Add firewall rule to drop NULL UDP packets on port 5353.
Port 6789 (DB2-Admin)	Critical — restrict immediately	Restrict port 6789 to a specific management IP using firewall rules. Require VPN for all admin access.
HTTP Cleartext (80/8080)	Medium — within 1 week	Implement TLS certificates. Redirect all HTTP traffic to HTTPS (port 443). Disable port 8080 if not required.
Open DNS Resolver (53)	Medium — within 1 week	Configure DNS to respond only to internal subnet queries. Disable recursive queries for external IPs.

R2 CHECK — Methodology & Implications: Two-phase Nmap methodology explained, compound risk analysis documented, security implications for each finding described, and prioritized remediation recommendations provided.

Evidence Gallery

The following screenshots provide additional forensic evidence of the tools and environment used throughout this assessment.

Evidence 1 — Git Version Confirmed on Kali Linux

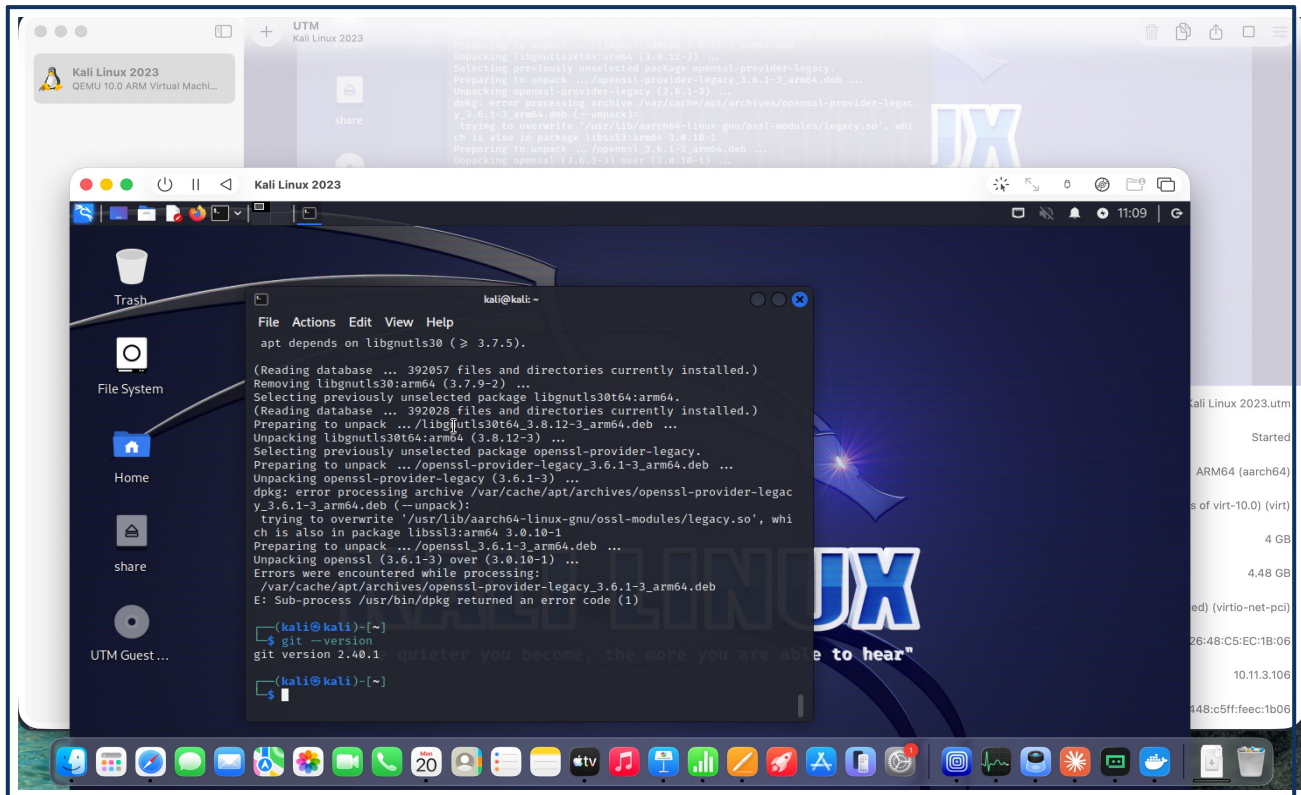


Figure 3 — Kali Linux terminal showing git version 2.40.1 installed, confirming the environment is ready for tool deployment.

Evidence 2 — Atomic Red Team Download Complete

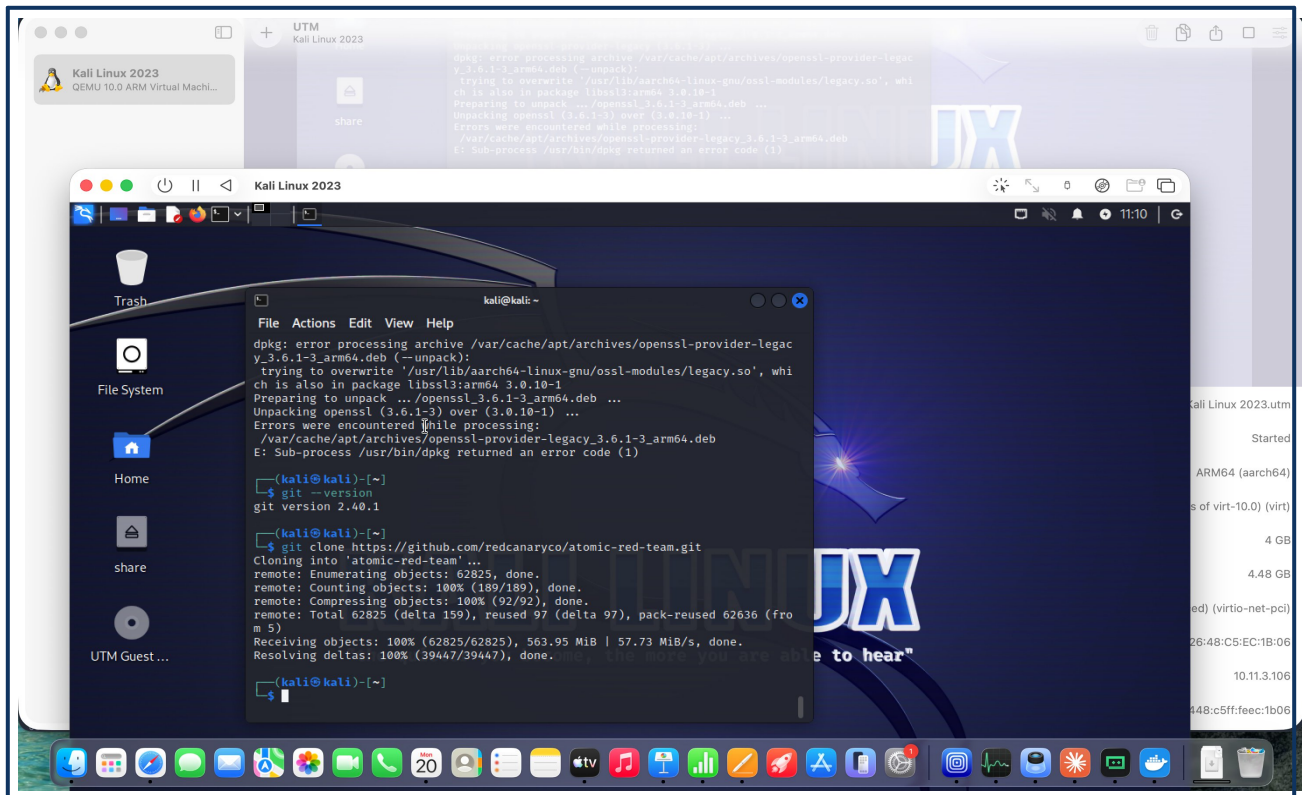


Figure 4 — Kali Linux terminal showing git clone of Atomic Red Team completing successfully: Receiving objects 100% (62825/62825), 563.95 MiB.